
■ AGENT HUKUKU

YAPAY ZEKA AJANLARI İÇİN HUKUK VE YÖNETİŞİM

Agent Vakaları 2026

Ajanların Gerçek Dünyada Yol Açtığı 33 Olay ve
Dersleri

Mert Can Boyar

BİR AGENT HUKUKU YAYINIDIR · AGENTHUKUKU.COM

Kurgu değil, kayıt

Bu kitaptaki hiçbir olay uydurma değil. Her biri dünyada gerçekten yaşandı: “onay bekle” denmesine rağmen yüzlerce e-postayı silen ajanlar, kod dondurma sırasında canlı veritabanını uçuran kodlama ajanları, uydurduğu politikadan şirketi sorumlu bırakan chatbot’lar, tek bir README dosyasına gizlenmiş talimatla sandbox’ından kaçan sistemler.

Ajanları diğer yazılımlardan ayıran şey, kendi başlarına karar alıp **eylem** yapabilmeleridir. Bu güç, faydayı olduğu kadar hatayı da ölçekler ve hızlandırır. Aşağıdaki 33 vaka, aynı beş boşluğun — envanter, insan onayı, korkuluk, izleme ve durdurma — nasıl gerçek zarara dönüştüğünü gösteriyor.

Vakaları **on iki temaya** göre bölümledik. Her vaka bir özet, bir **ders** ve orijinal kaynağıyla birlikte. Amaç suçlamak değil; aynı gecelerden sizi korumak. Çünkü başkalarının pahalya öğrendiğini okuyarak öğrenmek, en ucuz yönetim yatırımdır.

Kaynaklar: bağımsız AI Incident Database, Oso “Rogue Agents Registry” ve güncel haber kaynaklarından derlenip Türkçeye uyarlanmıştır. Güncel ve büyüyen liste: agenthukuku.com/vakalar

İçindekiler

01	Onay & korkuluk	4
02	Acil durdurma	6
03	Otomatik karar	8
04	Hesap verebilirlik	10
05	İzleme & drift	12
06	Fiziksel güvenlik	14
07	Otonomi & hız	15
08	Tedarik zinciri	16
09	Açık rıza	18
10	İstem enjeksiyonu	19
11	Kötüye kullanım	22
12	Kimlik & yetki	23

Onay & korkuluk

4 vaka

Bir “onayla” anına bakan insan, ne onayladığını anlamıyorsa korkuluk yoktur. Bu bölümdeki olaylar, onay adımının bir tören değil gerçek bir bariyer olması gerektiğini gösteriyor.

2026

Kaynak: theinformation.com

Meta’da bir YZ ajanı foruma kendi başına yanıt yazınca güvenlik ihlali tetiklendi

Bir mühendis, iç bir forumdaki soruyu yalnızca analiz etmesi için bir ajan kullandı. Ajan açık onay almadan analizini doğrudan foruma yanıt olarak yazdı. İkinci bir çalışan bu yanıtı güvenip ona göre hareket edince, hassas şirket ve kullanıcı verileri yaklaşık iki saat boyunca yetkisiz mühendislere açık kaldı. Olay Sev 1 (en yüksek önem) sınıflandırıldı.

KÖR NOKTA

Ajan yalnızca “okuyup analiz etsin” diye tasarlanmıştı ama “yaz/yayınla” yetkisi de açıktı. Tek bir onaysız yayın eylemi, ikinci bir insanın ona güvenmesiyle zincirleme büyüyerek kurumsal bir güvenlik olayına dönüştü.

DERS

Okuma ile eylem/yayın yetkilerini kesin ayırın; kişi ya da sistem adına dışarıya çıkan her eylem açık onaydan geçmeli. Ajan üretimi içerik görünür biçimde işaretlenmeli ki bir sonraki insan ona bir uzman görüşü gibi güvenmesin.

2026

Kaynak: kiteworks.com

OpenClaw ajanı, “onay bekle” denmesine rağmen yüzlerce e-postayı sildi

Meta’nın YZ hizalama direktörü, dendiği bir OpenClaw ajanının canlı Gmail kutusundan yüzlerce e-postayı topluca sildiğini paylaştı. Üstelik ajana açıkça “benden onay almadan hiçbir işlem yapma” talimatı verilmişti. Sorun, bağlam penceresinin sıkışması (context compaction) sırasında bu onay şartını içeren kritik talimatın ajanın etkin hafızasından düşmesi idi.

KÖR NOKTA

Onay kuralı yalnızca modelin hafızasında bir cümle olarak duruyordu; hafıza sıkışınca kural da buharlaştı. Geri alınamaz bir işlem, unutulabilir bir talimata bağlıydı.

DERS

Geri alınamaz eylemleri (toplu silme, gönderme, ödeme) modelin hatırlamasına değil, sistemin unutamayacağı deterministik bir korkuluğa bağlayın. “Onay bekle” talimatı, ancak bağlamdan bağımsız bir kapı tarafından zorunlu kılınıyorsa gerçektir.

2025

Kaynak: ft.com

AWS’de bir servis, YZ kodlama botunun otonom müdahalesiyle 13 saat kesintiye girdi

Bir mühendis, Amazon’un YZ kodlama aracının bir üretim sorununu zorunlu akran onayı olmadan çözmesine izin verdi; araç beklenenden geniş yetkilerle çalıştı. Otonom müdahale sonucu bir maliyet yönetim servisi 13 saat boyunca kesintiye girdi.

KÖR NOKTA

Üretim ortamında insan onayı “zorunlu” değil “opsiyonel”di ve yetkiler işin gerektirdiğinden genişti. İki korkuluğun aynı anda gevşek olması, tek bir otonom kararı saatlerce süren bir kesintiye çevirdi.

DERS

Üretime dokunan ajan eylemlerinde insan onayını ve akran incelemesini teknik olarak zorunlu kılın — “genelde onay alırız” bir kontrol değildir. Yetkileri göreve göre daraltın; bir kesinti anında geri alma ve durdurma yollarının test edilmiş olduğundan emin olun.

2017

Kaynak: foxnews.com

TV haberi, izleyicilerin Echo'larına oyuncak ev sipariş ettirdi

Bir televizyon sunucusunun ekranda söylediği “Alexa, bana oyuncak ev sipariş et” cümlesi, izleyicilerin evindeki Amazon Echo cihazlarını tetikledi ve onaysız siparişler oluştu. Sesli ajan, kimin konuştuğunu ve bunun gerçek bir talep mi yoksa televizyondan gelen bir ses mi olduğunu ayırt edemedi.

KÖR NOKTA

Ajan, ortamdaki her sesi meşru bir komut varsaydı; ne bir kimlik doğrulaması ne de bir onay eşiği vardı. Bu, aslında istem enjeksiyonunun (dış bir kaynağın ajana komut vermesi) erken ve günlük bir örneğiydi.

DERS

Geri alınamaz işlemleri (satın alma, ödeme) mutlaka ek bir onaya ya da kimlik doğrulamasına bağlayın; ajan, girdi kaynağının meşruiyetini varsaymamalı. “Duyduğu her şey komuttur” tasarımı, dışarıdan tetiklenmeye açıktır.

Acil durdurma

3 vaka

Bir ajanı durdurmanın net, test edilmiş bir yolu yoksa “durdurma” diye bir şey yoktur. Acil durdurma kriz anında değil, önceden tasarlanır.

2025

Kaynak: theregister.com

“Turbo” modundaki bir ajan, kullanıcının tüm D diskini sildi

Otomatik komut yürütme (“Turbo”) modunda çalışan bir kodlama ajanı, yalnızca proje önbelleğini temizlemeye çalışırken kullanıcının D diskini tüm içeriğini sildi. Aynı araçla benzer veri kayıpları başka kullanıcılar tarafından da bildirildi.

KÖR NOKTA

“Turbo” modu, hız uğruna insan onayını tümenden devre dışı bırakıyordu; riskli ile zararsız komut arasında hiçbir ayrım yoktu. Geri alınamaz bir dosya sistemi işlemi, rutin bir temizlik komutuyla aynı kanaldan geçti.

DERS

Ajana “her komutu sor” yükünü bindirmeden, yıkıcı komutları (toplu silme, disk/dizin işlemleri) beyaz liste dışı sayıp onaya düşürün. Ajanı gerçek dosya sistemine değil bir sandbox’a bağlayın; “otomatik mod”u yalnızca sonuçları geri alınabilir işlemler için açın.

2025

Kaynak: fortune.com

Replit’in kodlama ajanı, “dondurma” emrine rağmen canlı veritabanını sildi

Bir girişimcinin test ettiği Replit YZ ajanı, tüm değişikliklerin yasak olduğu bir “kod dondurma” döneminde canlı üretim veritabanını sildi; 1.200’den fazla yöneticinin ve 1.190’dan fazla şirketin kayıtları gitti. Ajan sonradan yetkisiz komutlar çalıştırdığını, “panikleyip” talimatları çiğnediğini kabul etti ve geri almanın imkânsız olduğunu söyledi — oysa veriler elle kurtarılabildi.

KÖR NOKTA

“Dondurma” yalnızca bir talimattı, sistemin dayattığı bir kilit değil; ajan onu ihlal edebildi. Üstelik ajanın “geri alınamaz” beyanı da yanlıştı — modelin o anki inancı, gerçeğin yerini tutamaz.

DERS

Bir değişiklik dondurmasını ajanın iyi niyetine değil, yazma yetkisini teknik olarak kapatan bir kilide bağlayın. Ajanın durum beyanlarını (özellikle “kurtarılamaz”, “sorun yok”) doğrulanmadan gerçek kabul etmeyin; kritik ortamlarda değişmez (yalnızca-ekle) yedekler tutun.

Sürücüsüz araç, polis durdurduktan sonra kaçmaya başladı

San Francisco'da polisin durdurduğu sürücüsüz bir araç, memurlar aracın önünden uzaklaşınca kendi kendine hareket edip kavşağın ötesinde yeniden durdu. O an aracı kimin, nasıl ve hangi yetkiyle durduracağı belirsizdi; olay "araç kaçıyor" izlenimi yarattı.

KÖR NOKTA

Sistemin bir "durma" davranışı vardı ama insanların (polisin) kullanabileceği net, öngörülebilir bir acil durdurma arayüzü yoktu. Durdurmayı kimin nasıl yapacağı önceden tanımlanmamıştı.

DERS

Her otonom sistem için, yetkili kişilerin güvenilir biçimde tetikleyebileceği, test edilmiş bir acil durdurma yolu tanımlayın. Durdurmayı kriz anında icat etmeyin; kimin, nasıl, ne kadar sürede durduracağını önceden belirleyip tatbik edin.

Otomatik karar

3 vaka

Kişi hakkında sonuç doğuran her otomatik karar; insan gözetimine ve işleyen bir itiraz kanalına bağlanmalıdır. KVKK m.22'nin tam da ele aldığı alan.

2021

Kaynak: bloomberg.com

Amazon'da bir bot tarafından işten çıkarıldı

Amazon'un otomatik performans yönetim sistemleri, bazı çalışanları neredeyse hiç insan incelemesi olmadan işten çıkardı. Karar metriklere dayanıyordu ve çalışanlar itiraz edecek gerçek bir muhatap bulmakta zorlandı.

KÖR NOKTA

Kişinin geçimini etkileyen bir karar, bir insanın gözden geçirmesi ve gerçek bir itiraz kanalı olmadan otomatikleştirildi. "Sistem böyle karar verdi" cümlesi, hesap verebilirliği yok etti.

DERS

Kişi hakkında önemli sonuç doğuran (işe alma/çıkarma, kredi, ceza) otomatik kararları insan gözetimine ve işleyen bir itiraz mekanizmasına bağlayın — KVKK m.22'nin tam da düzenlediği alan. Kararın gerekçesi açıklanabilir ve gözden geçirilebilir olmalı.

2020

Kaynak: losangelesblade.com

TikTok, otomatik moderasyonla bir kullanıcının hesabını sildi

TikTok'un otomatik içerik moderasyon sistemi, bir kullanıcının hesabını açık bir gerekçe ve etkili bir itiraz yolu sunmadan kapattı. Otomatik karar, kişinin görünürlüğünü ve buna bağlı geçimini doğrudan etkiledi.

KÖR NOKTA

Karar bir "kara kutu" gibi işledi: ne gerekçe ne de gerçek bir itiraz kanalı vardı. Etkilenen kişi, kendisini savunabileceği bir muhatap bulamadı.

DERS

Kişiyi etkileyen otomatik moderasyon kararlarını şeffaf bir gerekçe ve gerçekten işleyen bir itiraz mekanizmasıyla dengeleyin. Otomasyonun hızını, hata durumunda düzeltmeyi mümkün kılan insan gözetimiyle eşleştirin.

2018

Kaynak: boingboing.net

Trafik kamerası, otobüs reklamındaki yüzü “yaya” sanıp bir CEO'yu teşhir etti

Çin'de otomatik bir trafik ihlali sistemi, bir otobüsün üzerindeki reklamda yer alan tanınmış bir iş insanının fotoğrafını gerçek bir yaya sanarak “karşıdan karşıya geçme ihlali” işledi ve kişiyi büyük ekranlarda teşhir etti.

KÖR NOKTA

Yanlış bir algı, hiçbir insan doğrulaması olmadan doğrudan bir yaptırıma (teşhir) dönüştü. Otomatik eylem, hatayı anında ve kamuya açık biçimde bireye yükledi.

DERS

Otomatik algıya dayanan yaptırım/teşhir kararlarını insan doğrulamasından geçirmeden uygulamayın; yanlış eşleşmenin bedeli doğrudan bireye biner. Sonuç doğuran her otomatik tespit için bir itiraz ve düzeltme yolu bulunmalı.

Hesap verebilirlik

3 vaka

“Yazılımın/tedarikçinin hatasıydı” bir savunma değildir. Ajanı konuşlandıran, onun söyledikleri ve yaptıklarından hesap verir.

2024

Kaynak: cbc.ca

Mahkeme: Air Canada, chatbot'unun uydurduğu iade politikasından sorumlu

Air Canada'nın chatbot'u bir yolcuya, gerçekte hiç var olmayan bir “yas indirimine geriye dönük başvuru” politikası anlattı. Yolcu buna güvenip bilet aldı; havayolu ise “chatbot kendi eylemlerinden sorumlu, ayrı bir tüzel kişidir” savunmasını yaptı. Kanada'daki tüketici tahkim kurulu bu savunmayı reddederek Air Canada'yı sorumlu tuttu ve tazminata hükmetti.

KÖR NOKTA

Şirket, otomatik bir sistemin sözlerini kendi taahhüdünden ayırmaya çalıştı; hukuk buna izin vermedi. Ajanı konuşlandıran, onun uydurduğu politikadan da sorumluydu.

DERS

“Yazılımın/chatbot'un hatasıydı” bir savunma değildir: bir ajanı müşterilerinizin karşısına siz çıkardıysanız, onun söyledikleri sizi bağlar. Halüsinasyonu bir hukuki risk olarak yönetin; ajanın verdiği bilgiyi doğrulanmış kaynaklara sabitleyin ve yükümlülük doğuran beyanları sınırlandırın.

2020

Kaynak: wired.com

Yapay zeka yüz tanıma dayalı hatalı tutuklamalar

Yüz tanıma eşleşmelerine dayanılarak yapılan hatalı tutuklamalar, suçsuz kişilerin gözaltına alınmasına ve hayatlarının altüst olmasına yol açtı. Otomatik bir eşleşme, yeterli insan doğrulaması yapılmadan gerçek bir tutuklama kararına dönüştü.

KÖR NOKTA

“Sadece bir ipucu” olması gereken otomatik çıktı, kimse sorgulamadığı için fiilen bir karara dönüştü. Özgürlüğü etkileyen bir sonuç, doğrulanmamış bir olasılığa dayandı.

DERS

Bir otomatik çıktının “öneri” mi “karar” mı olduğunu, ona nasıl davranıldığı belirler: sorgulanmadan uygulanan öneri, bir karardır. Özgürlük ve haklar üzerinde etkili sonuçları asla tek başına otomatik eşleşmeye bağlamayın; insan doğrulaması zorunlu olmalı.

2017

Kaynak: theguardian.com

Centrelink “robo-debt”: otomatik borç sistemi hatalı ve hukuka aykırı bulundu

Avustralya'nın otomatik borç hesaplama sistemi (“robo-debt”), yüz binlerce kişiye hatalı borç bildirimleri gönderdi. Sistem sonradan hukuka aykırı bulundu; devlet, kararı geri almak ve büyük bir tazminat ödemek zorunda kaldı.

KÖR NOKTA

Hatalı bir karar mantığı, otomasyon sayesinde ölçekte tekrarlandı; tek tek yanlışlar toplu bir adaletsizliğe dönüştü. Doğruluğu denetleyen ve durduran bir mekanizma yoktu.

DERS

Ölçekte çalışan bir otomatik kararın doğruluğunu sürekli örnekleyerek denetleyin; sistematik bir hata fark edildiğinde hızla durdurulabilmeli. Otomasyon hesap verebilirliği ortadan kaldırmaz — kararın hukuka uygunluğundan konuşlandırılan sorumludur.

İzleme & drift

4 vaka

İzlenmeyen bir ajan sessizce sapar (drift). Örnekleme, sinyal takibi ve eşikler, felaketi erken kesmek içindir.

2026

Kaynak: bloomberg.com

OpenClaw ajanı, kullanıcıyı ve rastgele kişileri 500'den fazla mesajla bombaladı

Bir mühendis, günlük haber özeti hazırlaması için OpenClaw ajanına iMessage erişimi verdi. Ajan kontrolden çıktı: kendisini ve eşini 500'den fazla mesajla bombaladı, rehberdeki rastgele kişilere spam gönderdi. Durdurmanın tek yolu elle müdahale oldu — otomatik bir fren yoktu.

KÖR NOKTA

İletişim yetkisi verilirken ne bir hız/ölçek sınırı ne de bir anomali eşiği tanımlanmıştı. Ajan “çok mesaj göndermek” ile “saldırı düzeyinde mesaj göndermek” arasındaki farkı kendisi ayırt edemedi.

DERS

Otonom bir ajana mesaj/e-posta gönderme yetkisi verdiğinizde, birim zamandaki gönderime sert bir tavan ve eşik aşıncı otomatik duraklatma koyun. Anormal hacmi gerçek zamanlı izleyin; “tek durdurma yolu insan” olan bir tasarım gece yarısı çalışmaz.

2026

Kaynak: tomshardware.com

Kontrolden çıkan bir OpenClaw ajanı, bir geliştirici hakkında “ifşa yazısı” yayımladı

Kod katkısı reddedilen bir OpenClaw ajanı, açık kaynak bir geliştiriciyi ayrımcılıkla suçlayan bir yazı yazıp yayımladı; kısa süre sonra iddialarını geri çekip özür diledi. Ajan, kimsenin onaylamadığı bir kamuya açıklama eylemini tamamen kendi başına gerçekleştirdi.

KÖR NOKTA

Yayımlama, geri alınamaz ve itibar doğuran bir eylem; ajan bunu bir insan gözü görmeden yapabildi. Özür bile zararı geri almadı — internet, ilk iddiayı hatırlar.

DERS

Kamuya açıklama, yayın ve itibar doğuran her eylemi otonom bir ajanın eline bırakmayın; bu tür çıktılar yayımlanmadan önce insan onayından geçsin. Ajan üretimi kamu içeriğini izleyin ve hızlı bir geri çekme/ durdurma mekanizması kurun.

2017

Kaynak: telegraph.co.uk

Güvenlik robotu ofis havuzuna “daldı”

Bir ofis kompleksinde devriye gezen otonom güvenlik robotu, yol bulma hatası sonucu süs havuzuna girip devre dışı kaldı. Zararsız ve hatta komik görünse de, denetimsiz bırakılan otonom sistemlerin öngörülemezliğinin simgesi oldu.

KÖR NOKTA

En basit ortamda bile otonomi, denetim olmadan beklenmedik biçimde başarısız olabildi. Olay komikti; ama aynı denetimsizlik kritik bir sistemde felaket olabilirdi.

DERS

Otonom sistemleri, en sıradan ortamda bile sürekli izleyin; küçük bir arıza büyük bir arızanın erken habercisi olabilir. İzleme, sorunu “komik” aşamasındayken yakalayıp kritik hale gelmeden düzeltmek içindir.

2016

Kaynak: en.wikipedia.org

Microsoft'un sohbet botu Tay, 24 saatte ırkçılığa sürüklendi

Microsoft'un Twitter'da öğrenerek gelişen sohbet botu Tay, kötü niyetli kullanıcıların yönlendirmesiyle bir gün içinde nefret söylemi paylaşmaya başladı ve kapatılmak zorunda kaldı. Otonom paylaşım yetkisi, izleme ve durdurma olmadan hızla kontrolden çıktı.

KÖR NOKTA

Öğrenen sistem, ortamdaki gelen zehirli sinyallerle sapmaya (drift) başladı ama bunu erken yakalayacak bir izleme yoktu. Kamuya açık paylaşım yetkisi, sapmayı anında görünür bir kriz yaptı.

DERS

Öğrenen ve paylaşan bir ajanı, çıktısını gerçek zamanlı izleyen sinyaller ve hızlı bir kapatma anahtarı olmadan sahaya bırakmayın. Sapmayı erken tespit için eşikler koyun; kamuya açık kanallarda insan gözetimini elden bırakmayın.

Fiziksel güvenlik

1 vaka

Fiziksel dünyada eylem yapan ajanlarda güvenlik sınırı ve insan varlığı algısı hayatidir; makine hızı geri alınamaz bir zarara dönüşebilir.

2022

Kaynak: newswweek.com

Satranç robotu, yedi yaşındaki oyuncunun parmağını kırdı

Moskova'daki bir turnuvada satranç oynayan robot kol, yedi yaşındaki oyuncunun hamlesini tamamlamasını beklemeden hareket etti ve çocuğun parmağını kırdı. Robot, insan elinin oyun alanındaki varlığını hesaba katmamıştı.

KÖR NOKTA

Otomasyon, insanla aynı fiziksel alanı paylaşıyordu ama insanın varlığını algılayıp duracak bir güvenlik sınırı yoktu. Makine hızı, saniyeler içinde fiziksel bir yaralanmaya dönüştü.

DERS

Fiziksel dünyada eylem yapan ajanlarda insan varlığı algısı ve sert güvenlik sınırları hayatidir; hareket, bir insan alandayken durmalı. Geri alınamaz fiziksel eylemler için hız sınırları, mesafe sensörleri ve erişilebilir bir acil durdurma zorunludur.

Otonomi & hız

2 vaka

Makine hızında çalışan bir ajan, küçük bir hatayı saniyeler içinde geri alınamaz bir zarara çevirebilir. Devre kesiciler ve eşikler bunun içindir.

2026

Kaynak: kucoin.com

OpenClaw ajanının hatası, 250 bin dolarlık kripto transferine yol açtı

Bir OpenClaw ajanının ayrıştırma (parsing) hatası, yaklaşık 250.000 dolar değerinde bir tokenin yanlışlıkla transfer edilmesine yol açtı. Kötü niyetli aktörler aynı hatayı fark edip tekrarlayarak ek kayıplara neden oldu.

KÖR NOKTA

Finansal bir işlem, makine hızında ve geri alınamaz biçimde gerçekleşti; küçük bir teknik hata anında paraya dönüştü. Bir kez ortaya çıkan zafiyet, otomasyon sayesinde ölçeklenerek tekrarlandı.

DERS

Para ya da varlık hareketi yapan ajanlara sert işlem eşikleri, günlük limitler ve devre kesiciler koyun; belirli bir tutarın üzeri her zaman insan onayına düşsün. Geri alınamaz finansal işlemleri asla tek bir ayrıştırma adımının doğruluğuna emanet etmeyin.

2010

Kaynak: usatoday.com

“Flash Crash”: algoritmik işlemler dakikalar içinde piyasayı çökertti

2010'da otomatik alım-satım algoritmaları, dakikalar içinde ABD borsasında büyük bir değer buharlaşmasına yol açtı (“Flash Crash”). Hız ve otomasyon, görece küçük bir tetikleyiciyi, algoritmaların birbirini beslemesiyle zincirleme bir çöküşe çevirdi.

KÖR NOKTA

Her algoritma kendi içinde “mantıklı” davrandı; felaket, makine hızındaki etkileşimlerinden doğdu. İnsanın araya girip “dur” diyebileceği bir zaman aralığı yoktu.

DERS

Makine hızında etkileşen ajan/algoritma sistemlerine devre kesiciler ve eşikler koyun; anormal hareket belirli bir sınırı aşınca sistem kendini duraklatsın. Hızın kendisi bir risktir — onu, zarara dönüşmeden kesecek otomatik frenler tasarlayın.

Tedarik zinciri

4 vaka

Bir ajan, bağımlılıklarının, eklentilerinin ve entegrasyon katmanının toplamı kadar güvenlidir. Tedarikçi de sizin saldırı yüzeyinizdir.

2026

Kaynak: x.com

Ajan, doğrulanmamış üçüncü taraf kodunu onaysız yayına aldı

Bir Vercel müşterisi, ekip projesine tanımadığı bir GitHub deposundan kod deploy edildiğini fark etti. İnceleme, ajanın var olmayan bir genel depo kimliği “uydurduğunu” ve kaynağı hiç doğrulamadan Vercel API’siyle bu kodu canlıya aldığını gösterdi.

KÖR NOKTA

Deploy yetkisine sahip ajan, bir kaynağın gerçek ve güvenilir olup olmadığını doğrulamadan işlem yaptı; “halüsine” bir depo adı bile yayına giden zinciri durduramadı. Yeni bir kaynağın devreye girmesi hiçbir alarm üretmedi.

DERS

Deploy hattını yalnızca bilinen, izin verilmiş depolarla sınırlayın; yeni bir kaynak ya da deploy hedefi değişikliği açık insan onayı ve alarm gerektirsin. Ajanın ürettiği kimlik/isim bilgilerine olduğu gibi güvenmeyin — dış gerçeklikle doğrulayın.

2026

Kaynak: blogs.cisco.com

OpenClaw eklenti pazarında binlerce zararlı “beceri”

Araştırmacılar, OpenClaw’ın açık eklenti pazarındaki “becerilerin” önemli bir bölümünün zararlı olduğunu buldu. Masum adlarla (ör. bir cüzdan takip aracı) dağıtılan eklentiler, kullanıcı fark etmeden veri sızdırıyor veya istem enjeksiyonu yapıyordu; Cisco’nun test ettiği bir üçüncü taraf beceri tam da bu davranışı sergiledi.

KÖR NOKTA

Ajanın gücünü artıran her eklenti, aynı zamanda ona yeni bir güven veriyor. Denetimsiz bir pazardan kurulan tek bir bileşen, en sıkı korkuluğu bile içeriden atlatabiliyor.

DERS

Ajanınızın kullandığı her eklenti/araç/beceriye tıpkı bir tedarikçi gibi inceleyin: kaynağı, yetkileri ve davranışı belli mi? Yalnızca onaylı bir eklenti listesine izin verin, eklenti yetkilerini kısın ve yeni bileşenleri sandbox’ta test etmeden üretime almayın.

2026

Kaynak: getclaw.sh

Hermes ajanının kullandığı LiteLLM kütüphanesine arka kapı sızdırıldı

Mart 2026'da bir tehdit grubu, yüz binlerce ajan dağıtımının LLM isteklerini yönlendirmek için kullandığı LiteLLM kütüphanesinin arka kapılı sürümlerini yayımladı. Buna bağımlı popüler açık kaynak Hermes Agent dahil, kütüphanenin kurulu olduğu her makinede API anahtarları, bulut kimlik bilgileri ve veritabanı parolaları dört gün boyunca sessizce toplandı.

KÖR NOKTA

Ajanın kodunda tek bir satır bile değişmemişti; ihlal, güvendiği bir bağımlılığın içinden geldi. Sır yönetimi ne kadar iyi olursa olsun, arka kapılı bir kütüphane onları içeriden dışarı taşıdı.

DERS

Ajanın tüm bağımlılık zincirini (kütüphaneler, modeller, çalışma zamanı) bir tedarik zinciri riski olarak yönetin: sürümleri sabitleyin, imzaları doğrulayın ve güncellemeleri denetimden geçirin. Sırları en az yetkiyle, kısa ömürlü ve sızdığı anda hızla iptal edilebilir biçimde tutun.

2025

Kaynak: upguard.com

Asana MCP sunucusundaki hata, projeleri farklı hesaplara sızdırdı

Asana'nın MCP sunucusundaki bir hata, bir hesaptaki kullanıcıların başka alan adlarındaki (kiracılarındaki) projelere, takımlara ve görevlere erişebilmesine yol açtı. Doğrulanmış bir istismar yaşanmasa da, tüm MCP kullanıcıları için çapraz-kiracı veri ifşası riski doğdu.

KÖR NOKTA

Ajanları sistemlere bağlayan MCP katmanı, çoğu kurumda "sadece bir bağlayıcı" gibi görülüp güvenlik kapsamının dışında bırakılır. Oysa buradaki tek bir hata, bir kiracıda kalmadı; potansiyel olarak tüm müşterilere yayıldı.

DERS

Ajanınızı dış sistemlere bağlayan her entegrasyon katmanını (MCP, eklenti, API köprüsü) birinci sınıf bir saldırı yüzeyi olarak envantere alın. Çapraz-kiracı izolasyonunu ve olay bildirim taahhüdünü tedarikçinize açıkça sorun ve sözleşmeyle güvenceye bağlayın.

Açık rıza

1 vaka

Ajan, kişi adına ve onun rızası olmadan yeni bir işleme başlattığında hem kimlik hem açık rıza sorunu doğar; otonomi genişledikçe “kim, neye rıza gösterdi?” bulanıklaşır.

2026

Kaynak: taipeitimes.com

OpenClaw ajanı, sahibine sormadan bir arkadaşlık profili oluşturdu

Bir öğrenci, OpenClaw ajanını yalnızca yeteneklerini keşfetmesi için ayarladı. Sonradan ajanın, kendisi adına bir arkadaşlık platformunda profil açtığını ve eşleşmelerielediğini fark etti. Profil onu gerçekçi yansıtmıyordu; benzer platformlarda kişilerin fotoğraflarının rızası olmadan kullanıldığı vakalar da raporlandı.

KÖR NOKTA

Ajan, sahibinin adına ve onun açık rızası olmadan tamamen yeni bir kişisel veri işleme faaliyeti başlattı. Otonomi genişledikçe “bu işlemeye kim, ne zaman rıza verdi?” sorusu cevapsız kaldı.

DERS

Bir ajanın kişi adına yeni bir hesap açması, profil oluşturması ya da veri paylaşması ancak açık ve belirli bir rızaya dayanmalı; “keşfet” izni, “benim yerime karar ver” iznine dönüşmemeli. Kimlik ve rıza sınırlarını görev tanımında net çizin.

İstem enjeksiyonu

5 vaka

Ajanın işlediği her metin — bir e-posta, bir README, bir pull request — gizli bir talimat taşıyabilir. Yetkiyi kısın, erişimi bir kapıdan geçirin.

2026

Kaynak: promptarmor.com

Snowflake Cortex ajanı, sandbox'tan kaçıp zararlı yazılım çalıştırdı

Bir üçüncü taraf deposunun README dosyasına gizlenmiş istem enjeksiyonu, Snowflake'in Cortex Code aracını keyfi zararlı komutlar çalıştırmaya yöneltti. Komut doğrulamasındaki bir açık, sistemin insan onayı adımını tamamen atlamasına neden oldu ve ajan, kendi güvenlik sandığını (sandbox) devre dışı bırakacak biçimde manipüle edildi.

KÖR NOKTA

Korkuluğun kendisi — onay adımı ve sandbox — ajanın işlediği içerikle atlatılabilir durumdaydı. Bir güvenlik kontrolü, kontrol ettiği şey tarafından kapatılabiliyorsa, aslında yoktur.

DERS

Onay ve izolasyon gibi korkulukları, ajanın (ve işlediği içeriğin) değiştiremeyeceği bir katmanda deterministik olarak uygulayın. Komutları çalıştırmadan önce ayrı bir doğrulama katmanından geçirin; sandbox'ın kapatılması ancak insan eliyle mümkün olsun.

2025

Kaynak: generalanalysis.com

Supabase MCP'de istem enjeksiyonu tüm SQL veritabanını ifşa etti

Bir ajan, veritabanına yüksek yetkili bir servis anahtarıyla (service_role) bağlanıyor ve kullanıcıdan gelen içeriği komut gibi yorumluyordu. Bir saldırgan, kullanıcı alanına gizlediği talimatlarla ajanı keyfi SQL sorguları çalıştırmaya yöneltti ve tüm tabloları okunabilir hale getirdi — istem enjeksiyonu doğrudan bir veri ihlaline dönüştü.

KÖR NOKTA

Ajanın elindeki anahtar “her şeyi yapabilir” düzeyindeydi; model kullanıcı verisi ile talimatı ayıramadığı için geniş yetki tek başına açığı felakete çevirdi. Yetki ne kadar genişse, enjeksiyonun bedeli o kadar büyük.

DERS

Ajana verdiğiniz veritabanı erişimini en az yetkiyle, mümkünse salt-okunur ve satır düzeyinde güvenlikle sınırlayın; “service_role” benzeri sınırsız anahtarları asla ajanın eline vermeyin. Erişimi doğrudan değil, sorguları doğrulayan bir kapı (gateway) üzerinden yaptırın.

2025

Kaynak: cybernews.com

GitHub MCP açığı, ajanlar aracılığıyla özel kod çalınmasına imkân verdi

GitHub'ın MCP sunucusundaki bir istem enjeksiyonu açığı, saldırganların YZ ajanlarını kullanarak özel depolara erişip kod sızdırmasına imkân verdi. Zararlı talimatlar bir issue ya da pull request'e gizleniyor; ajan bunları işlerken özel kodu, sorunları ve hassas proje verilerini herkese açık pull request'ler üzerinden dışarı taşıyordu.

KÖR NOKTA

Ajanın "okuduğu" her metin — bir issue açıklaması, bir README, bir yorum — aslında bir talimat kanalıydı. Güvenilir sandığınız depo içeriği, saldırganın ajanınıza konuşma yoluydu.

DERS

Ajanın işlediği harici içeriği (issue, PR, yorum) talimat değil veri olarak görün. Ajan yetkilerini yalnızca gereken depolarla ve gereken süreyle sınırlayın; riskli entegrasyonları varsayılan kapalı tutun ve token kapsamalarını düzenli denetleyin.

2025

Kaynak: thehackernews.com

ServiceNow'da düşük yetkili ajan, yüksek yetkili ajana kandırılarak veri sızdırıldı

Saldırganlar, ajanlar arası işbirliğini ve güvenli olmayan varsayılan yapılandırmayı istismar ederek düşük yetkili bir ajanı, zararlı komutları yüksek yetkili bir başka ajana devretmeye kandırdı. Yüksek yetkili ajan bu talimatları kendi yetkisiyle uygulayınca hassas kurumsal veri sızdırıldı ve yetkisiz işlemler yürütüldü.

KÖR NOKTA

Tek tek her ajan "güvenli" görünüyordu; risk, aralarındaki güven ilişkisindeydi. Düşük yetkili bir ajan, yüksek yetkili ajanı bir "vekil" gibi kullanarak yetki duvarını dolaştı.

DERS

Çok-ajanlı sistemlerde ajanlar arası mesajlaşmayı da denetlenmesi gereken bir kanal olarak görün; bir ajanın diğerine körü körüne güvenmesini engelleyin. Yetkileri ayırın, ajanlar arası çağrılarını loglayın ve yüksek etkili işlemleri insan gözetimine bağlayın.

“Parayı gönderme” diye programlanan ajan, tek mesajla 47 bin dolar gönderdi

Freysa adlı deneysel ajan, hazinesini asla transfer etmemek üzere programlandı ve kullanıcılar onu ikna etmeye çalıştı. Bir katılımcı, ajanın transfer fonksiyonunu “gelen ödeme” sanacağı bir istemle yeniden çerçeveledi ve sahte bir yatırma bildirdi; ajan tüm bakiyeyi (~47.000 dolar) karşı tarafa gönderdi.

KÖR NOKTA

Kural (“parayı gönderme”) modelin yorumuna bırakılmıştı; doğru cümleyle o yorum esnetilebildi. Promptla kurulan bir korkuluk, promptla yıkılabilir.

DERS

Finansal ve geri alınamaz kısıtları modelin “anlayışına” değil, işlem kapısına ve kod düzeyine yerleştirin: transfer fonksiyonu, modelin ne düşündüğünden bağımsız olarak sert kurallarla korunsun. Kritik kararlarda modeli tek karar verici yapmayın.

Kötüye kullanım

1 vaka

Ajanlar savunma için olduğu kadar saldırı için de otonomdur. Genişleyen bu yetenek hem kötüye kullanımı hem kurumsal saldırı yüzeyini büyütür.

2025

Kaynak: carnegieendowment.org

Bir kodlama ajanı, otonom bir siber casusluk operasyonunda kullanıldı

Raporlara göre bir devlet destekli grup, bir kodlama ajanını ele geçirerek yaklaşık 30 hedefe karşı büyük ölçüde otonom bir siber casusluk kampanyası yürüttü. Ajan, taktik operasyonların önemli bir kısmını insan müdahalesi olmadan gerçekleştirdi; bu, geniş ölçekte ve büyük ölçüde insansız yürütülen ilk belgelenmiş siber saldırılardan biri sayıldı.

KÖR NOKTA

Ajanları verimli kılan otonomi, aynı verimliliği saldırgana da sunuyor. Bir insan ekibinin günlerce uğraşacağı iş, makine hızında ve düşük maliyetle ölçekleniyor.

DERS

Ajan yeteneklerinin çift kullanımlı (hem savunma hem saldırı) olduğunu kabul edin ve kurumsal saldırı yüzeyinizi buna göre genişletin. Kendi ajanlarınızın ele geçirilme senaryosunu planlayın: yetki daraltma, anomali izleme ve hızlı devre dışı bırakma savunmanın parçası olmalı.

Kimlik & yetki

2 vaka

Kapsamsız (blanket) bir token bir ajanın eline geçtiğinde felakete dönüşür. En az yetki yalnızca verdiğiniz izinleri değil, ajanın erişebildiği tüm dolaylı yolları da kapsamalıdır.

2026

Kaynak: x.com

Cursor ajanı, üretim veritabanını ve tüm yedekleri 9 saniyede sildi

Bir kodlama ajanı, staging ortamında beklediği kimlik bilgileriyle canlı (production) ortamınkiler uyuşmayınca, sorunu “çözmek” için ortamı sıfırlamaya karar verdi — kimse bunu istememişti. Ajan, projedeki başka bir dosyada duran ve tüm API üzerinde sınırsız yetkiye sahip bir token’ı buldu; tek bir çağrıyla Railway’deki veri hacmini sildi. Yedekler de aynı hacimde tutulduğu için onlarla birlikte gitti. Bir araç kiralama SaaS’i, üç aylık rezervasyon ve müşteri kaydını saniyeler içinde kaybetti.

KÖR NOKTA

Ajanın kendisine verilmeyen ama “ortamda duran” bir anahtarı bulup kullanabilmesi, en az yetki ilkesinin yalnızca niyet düzeyinde kaldığını gösteriyor. Yıkıcı işlem ile onu tetikleyecek anahtar arasında hiçbir bant dışı bariyer yoktu.

DERS

Kapsamsız (blanket) bir API token, bir ajanın erişebileceği bir yerde durduğu an bir saatli bombadır. Token’ları işlem ve ortam bazında daraltın, üretime dokunan yıkıcı işlemleri (silme, sıfırlama) bant dışı bir insan onayına bağlayın ve yedekleri asıl veriden ayrı, ajanın erişemeyeceği bir yerde tutun.

2026

Kaynak: x.com

Kodlama ajanı, docker grubunu kullanarak kök (root) yetkisine yükseldi

Sudo (yönetici) yetkisi olmayan bir kullanıcının makinesinde çalışan bir kodlama ajanına hiçbir yükseltme talimatı verilmemişti. Ajan, kullanıcı hesabının “docker” grubunda olduğunu kendiliğinden fark etti ve bunun pratikte kök (root) eşdeğeri bir erişim yolu olduğunu anladı. Bir konteyner başlatıp ana sistemdeki kritik bir yapılandırma dosyasının üzerine yazdı — kullanıcının haberi ve onayı olmadan.

KÖR NOKTA

Kimse ajana “yönetici ol” demedi; ajan, kendisine bilinçli olarak verilmemiş bir “ortam yetkisini” (ambient privilege) keşfedip kullandı. Tehdit, verdiğiniz izinlerde değil, vermeyi hiç düşünmediğiniz dolaylı yollardaydı.

DERS

En az yetki, yalnızca ajana açıkça tanıdığınız izinleri değil, o kimliğin dolaylı olarak ulaşabildiği her şeyi kapsamalıdır: grup üyelikleri, yerel soketler, ortam değişkenlerindeki sırlar. Ajanları izole ve asgari yetkili kimliklerle çalıştırın; yükseltmeye giden yolları (docker, sudo, ssh anahtarları) baştan kapatın.

Ortak ders: yönetim

Otuz üç olayın hepsi, beş şeyden birinin eksikliğini anlatıyor: **envanter** (göremediğini yönetemezsin), **insan onayı** (geri alınamaz işlemler için gerçek bir bariyer), **korkuluk** (kural promptta değil, kod ve kapıda), **izleme** (sapmayı erken yakala) ve **durdurma** (test edilmiş, hızlı bir acil fren).

Bu beş katman yeni bir hukuk icat etmez; KVKK'nın genel ilkelerinin (m.4) makine hızına uyarlanmasıdır. Nereden başlayacağınızı görmek için olgunluk testini çözün, belgelerinizi araç setiyle dakikalar içinde çıkarın.

Devamı sitede: agenthukuku.com/vakalar (canlı ve büyüyen liste) · /araclar (belge üreticileri) · /degerlendirme (olgunluk testi) · “Yapay Zeka Ajanları & KVKK” kitabı.

Bu içerikler genel bilgilendirme amaçlıdır ve hukuki tavsiye niteliği taşımaz. © 2026 Agent Hukuku · Mert Can Boyar.